

אנטומיה של הונאה: לנווט במגפת הפישונג



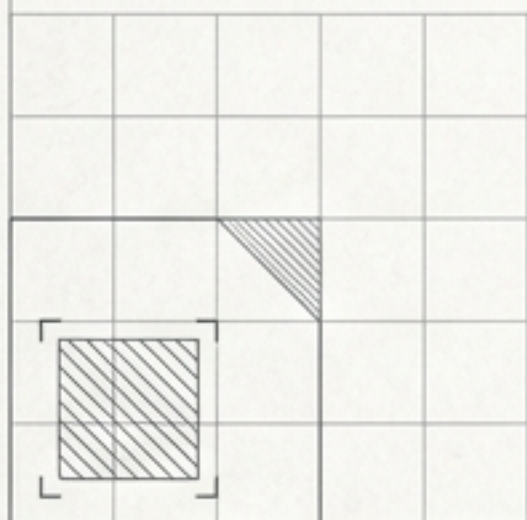
הבנת הווקטורים, הפסיכולוגיה ומערכות
ההגנה נגד איום הסייבר הנפוץ בעולם

מסמך סקירה מודיעינית | מהדורת חורף

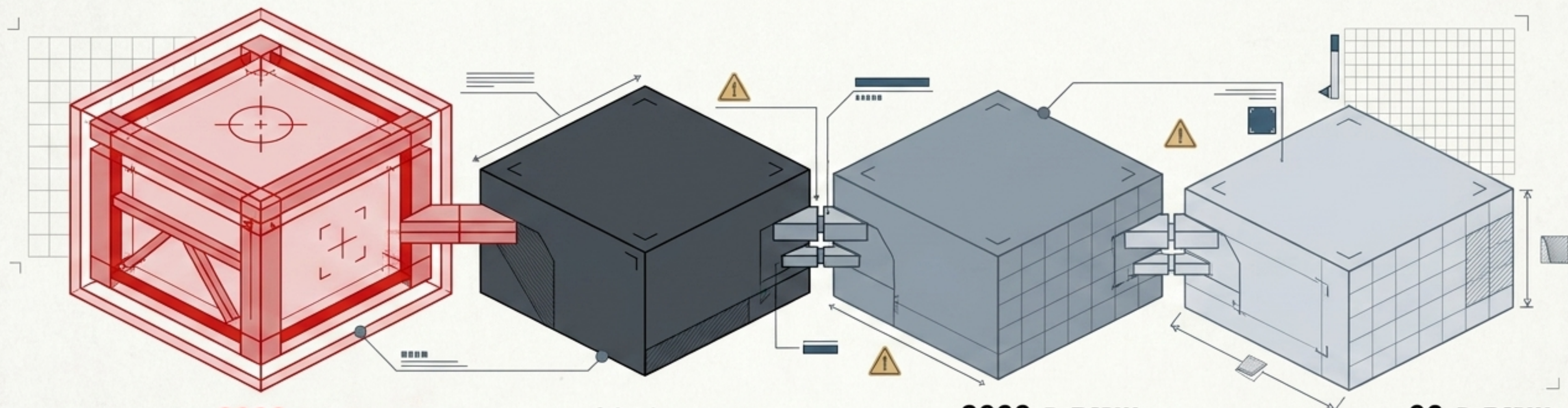
היקף האיום

94%

(מהארגונים הותקפו בשנת 2023)



עידני הפישינג: אבולוציה של איום



שנות ה-90

עידן ה-Script Kiddie:
התחזה לאנשי צוות
צוות ב-AOL (באמצעות
AOHell) לגנבת
סיסמאות ידנית. המונח
נטבע ב-1995.

שנות ה-2000

העידן הפיננסי: פשע
מאורגן (כגון רשת
RBN) ממקד התקפות
נגד בנקים מסחריים
ומערכות תשלום
(E-gold).

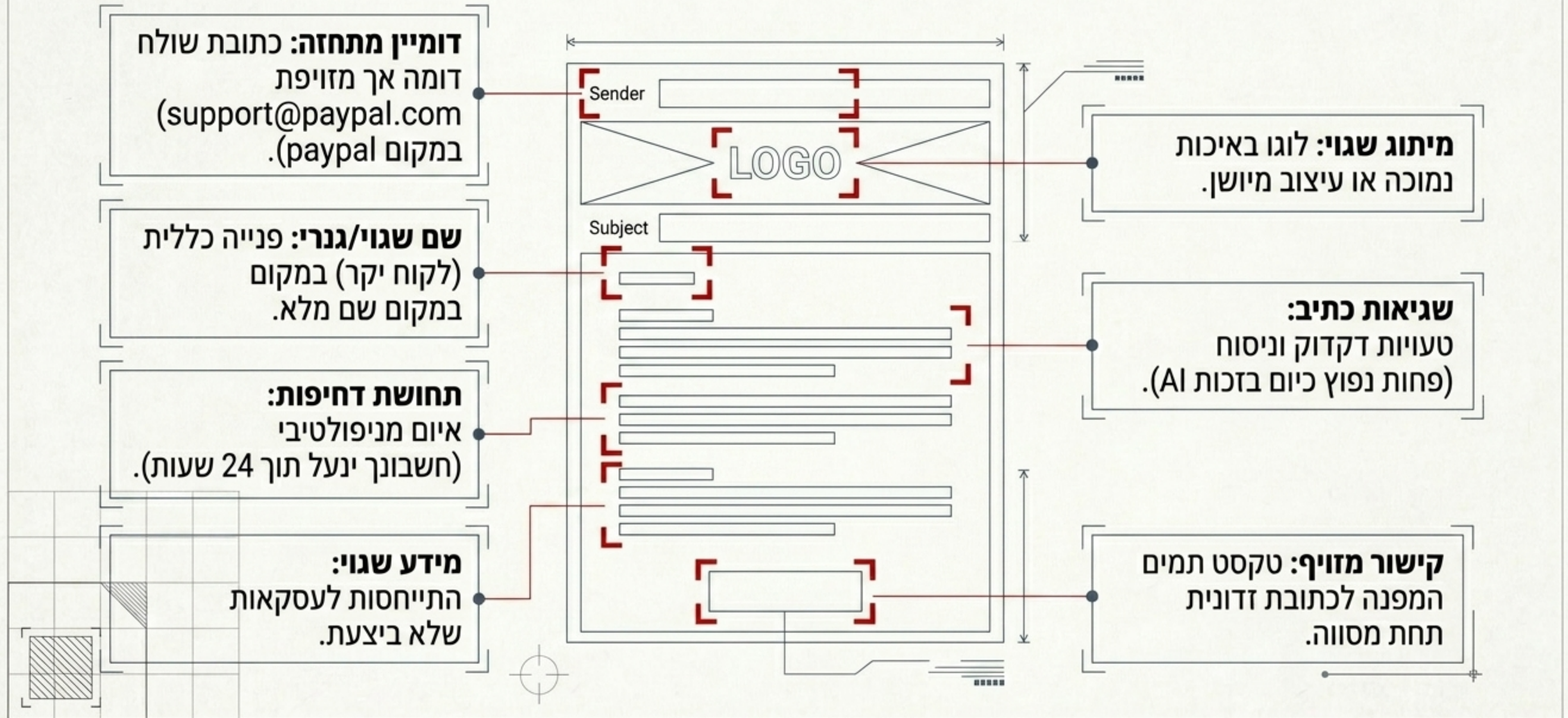
שנות ה-2010

עידן מעורבות המדינות:
תקיפות ממוקדות (Phishing)
מצד קבוצות חסות
מדינה כמו Fancy Bear נגד
בכירים, ה-DNC ורשתות
צבאיות.

שנות ה-2020

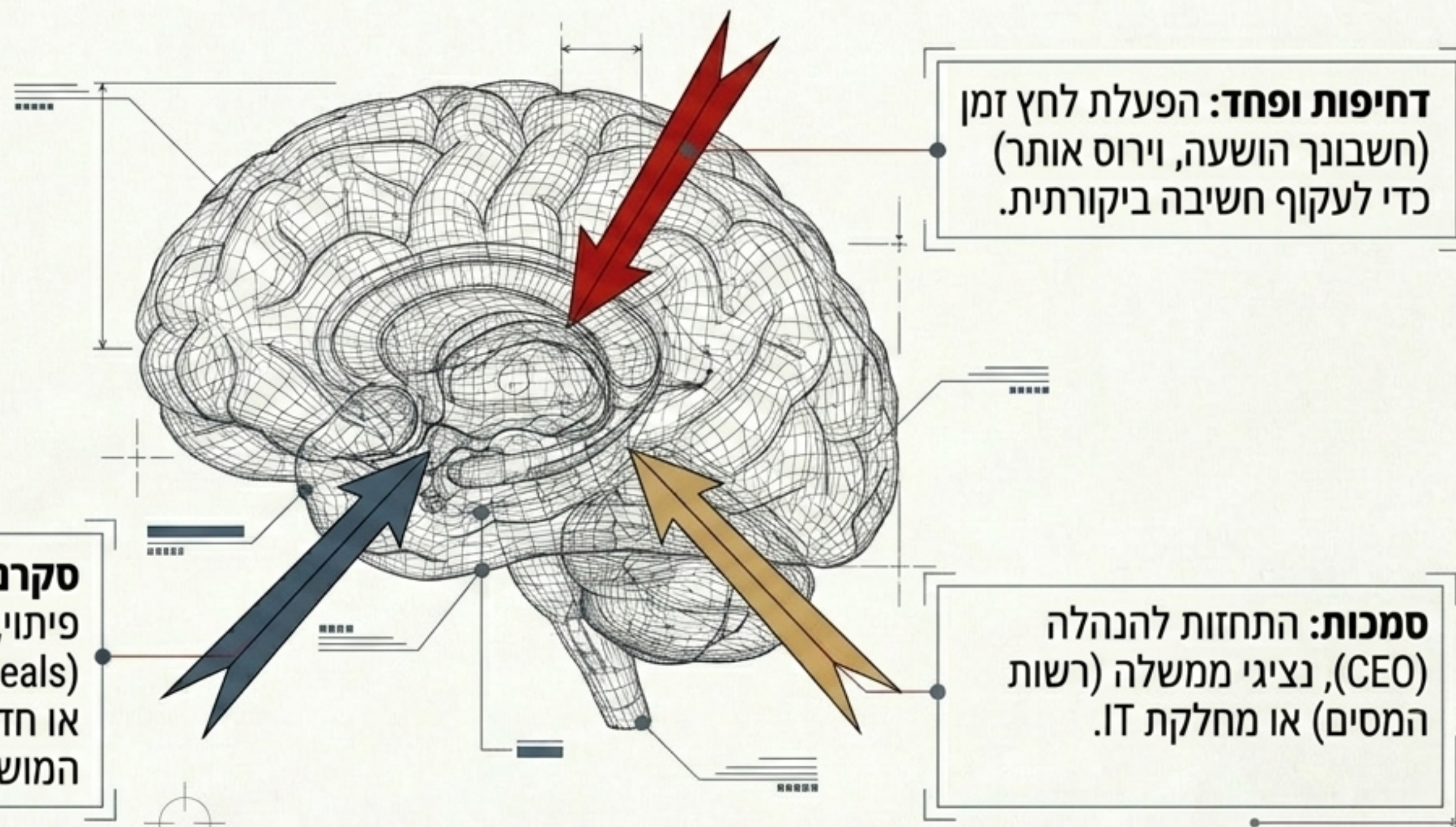
עידן ה-AI ו-PhaaS: אוטומציה
מוחלטת, פלטפורמות
פישינג כשירות (כמו
Darcula) ועקיפת מנגנוני
אימות דו-שלבי (2FA)
בזמן אמת.

אנטומיה של פיתיון



הגרעין הפסיכולוגי: הנדסה חברתית

התוקפים אינם פורצים למערכות; הם מפעילים מניפולציות על בני אדם כדי שאלו יפתחו את הדלתות בעצמם.

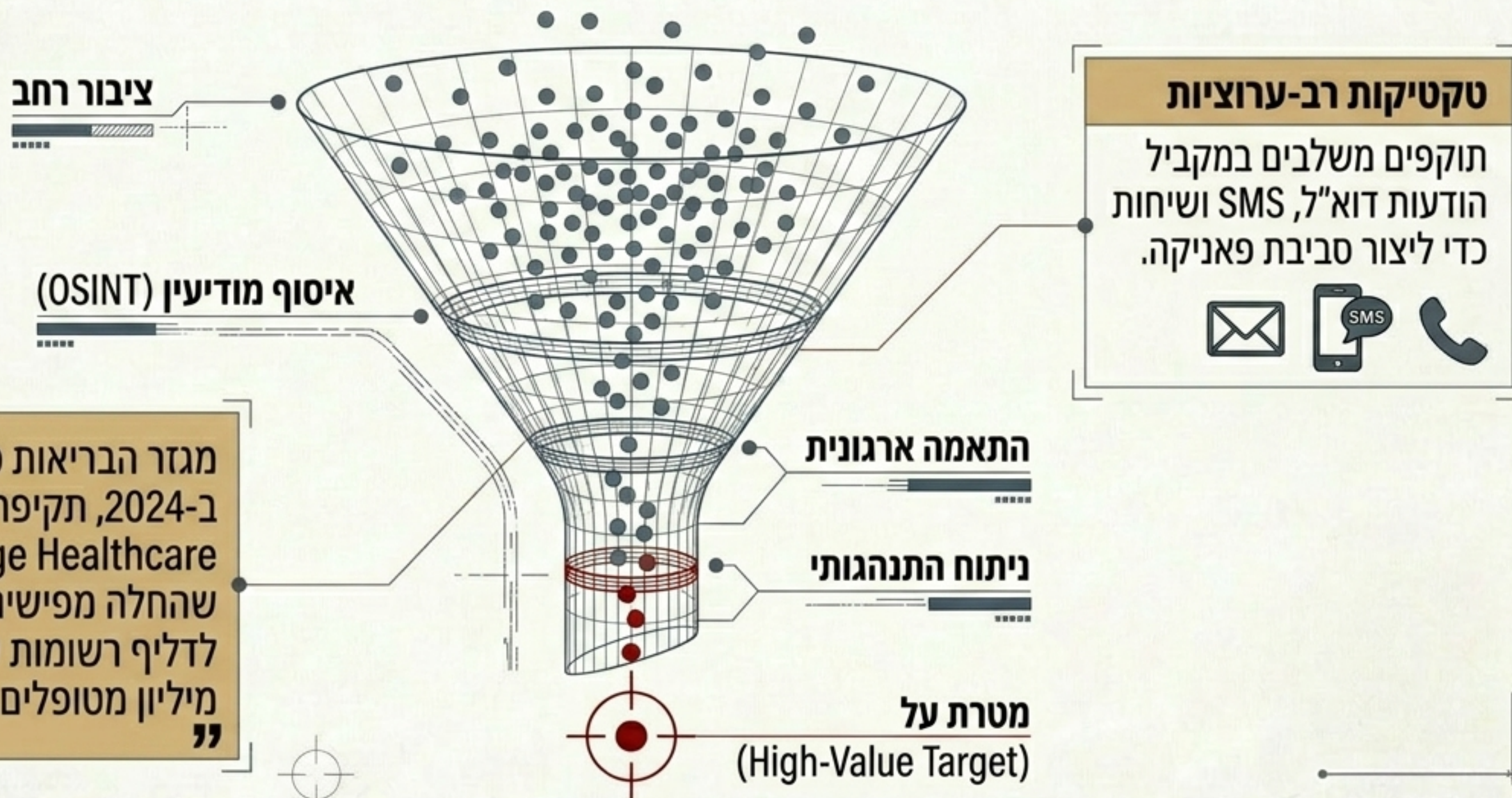


טקסונומיית הפישנג

שיטת הטעיה	רוחב תקיפה	מדיום	וקטור
שליחת אלפי הודעות גנריות לציבור הרחב בתקווה לאחוז המרה מזערי.	המוני (Bulk) ● ● ●	דוא"ל	 Email Phishing
איסוף מודיעין מדויק (OSINT) והתאמה אישית של ההודעה ליעד קונקרטי.	ממוקד מאוד ●	דוא"ל/משולב	 Spear Phishing
שימוש בשיחות אוטומטיות וזיוף מספרי טלפון ליצירת אמינות והוצאת פרטים.	משתנה ● ●	קול (VoIP)	 Vishing
ניצול אמון המשתמשים בטלפון הנייד וקישורים מקוצרים המוסתרים במסך הקטן.	רחב/ממוקד ● ●	מסרונים (SMS)	 Smishing

צלילת עומק: פישניג ממוקד וציד לויתנים (Whaling)

תקיפות Spear Phishing יעילות פי כמה מפישניג רגיל משום שהן משתמשות במידע ארגוני פנימי להעלאת רמת האמינות.



הגשר מהפיזי לדיגיטלי: Quishing



שימוש בקודי QR זדוניים כדי לגרום לקורבנות למסור מידע רגיש.

עקיפת מסנני דואר אלקטרוני וטכנולוגיות הגנה מסורתיות, שכן הקוד נסרק ישירות ממכשיר הקצה האישי של המשתמש.

מדבקות המודבקות על גבי קודים לגיטימיים במרחב הפיזי (מדי החניה, פרסומות, תחנות רכבת) או שילוב בקובצי PDF ורשתות חברתיות.

הסוואה טכנולוגית: מניפולציית קישורים

התקפות הומורגף (Homograph Attacks) וזיוף IDN (Internationalized Domain Name).

עין אנושית

🔒 apple.com

🔒 apple.com

האתר נראה לגיטימי לחלוטין לעין האנושית.

ראיית מחשב

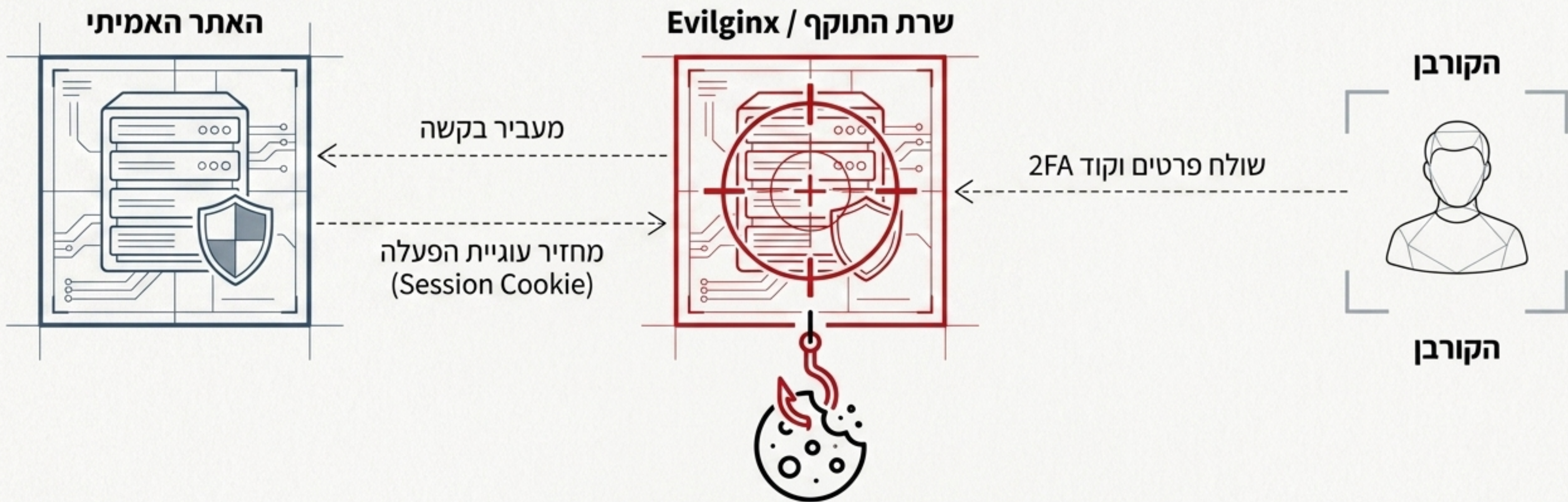
>_

Punycode Translation:
xn--pple-43d.com

האות הלטינית 'a' מוחלפת באות הקירילית 'a'.
הקורבן מנותב לשרת עוין.

האיום המתקדם: אדם באמצע (Man-in-the-Middle)

כלים כמו Evilginx הפכו את הפישינג לפלטפורמת תיווך הפועלת בזמן אמת, עוקפת גם אימות דו-שלבי (2FA).



התוקף גונב את עוגיית ההפעלה. כעת יש לו גישה מלאה לחשבון, ללא צורך לשמור את הסיסמה או את קוד ה-2FA.

סינתזה: שרשרת ההריגה של הפישינג המודרני



המגן - חלק א': סינון טכנולוגי

מסנני דואר מבוססי ML

אלגוריתמים מעבדים שפה טבעית (NLP) לזיהוי כוונות זדוניות וחסידת דומיינים מזויפים לפני ההגעה לתיבה.

אזהרות דפדפן (Safe Browsing)

סינון בזמן אמת ע"י דפדפנים ותוספים החוסמים אתרים מושחרים.

ניהול דיגיטליים (DRP)

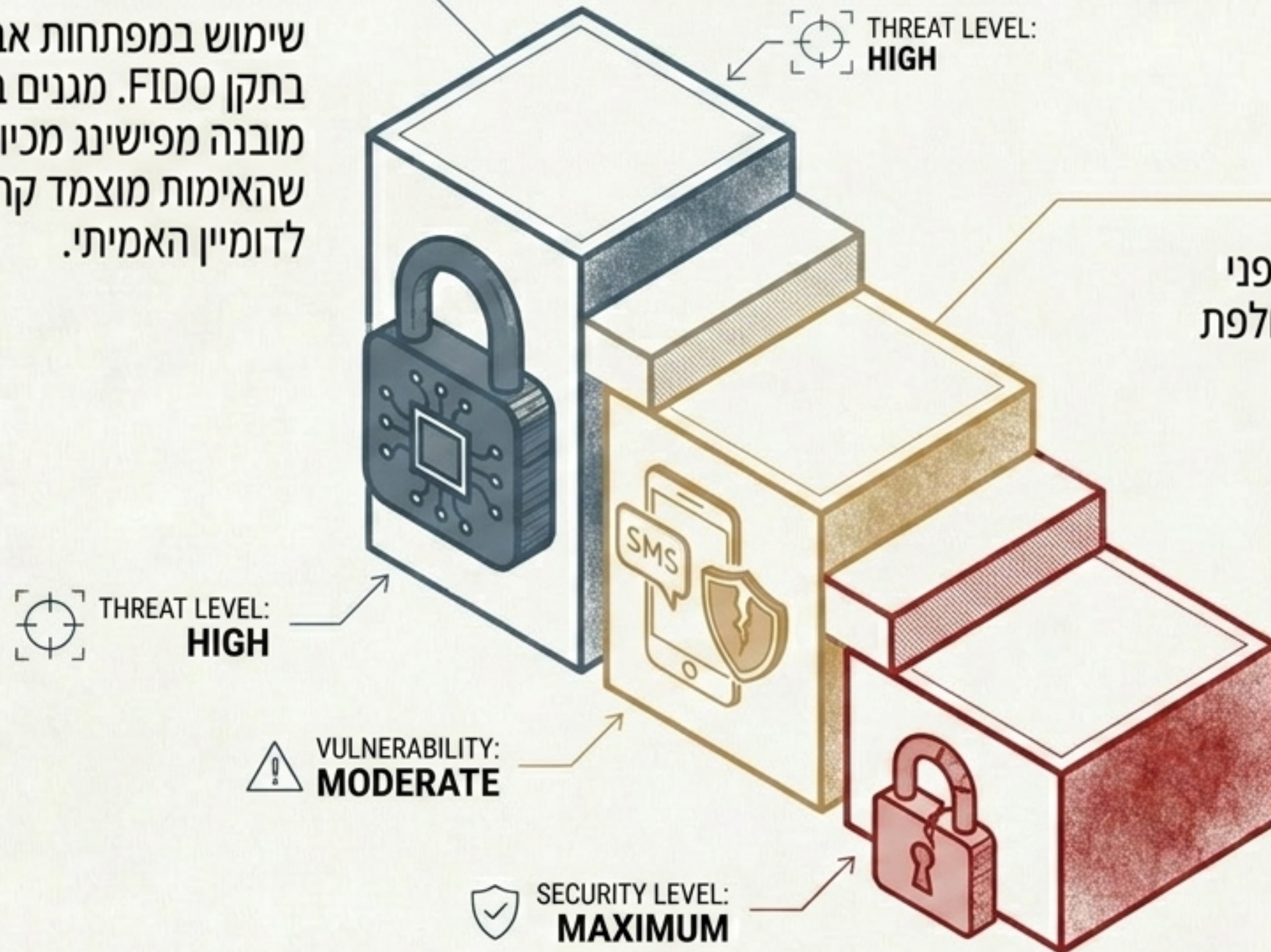
חברות וכלים אוטומטיים שמזהים תשתיות מתחזות ומסירים אותן באופן יזום.



המגן - חלק ב': הקשחת האימות

אימות חומרה ו-WebAuthn

שימוש במפתחות אבטחה פיזיים
בתקן FIDO. מגנים באופן
מובנה מפישיוג מכיוון
שהאימות מוצמד קריפטוגרפית
לדומיין האמיתי.



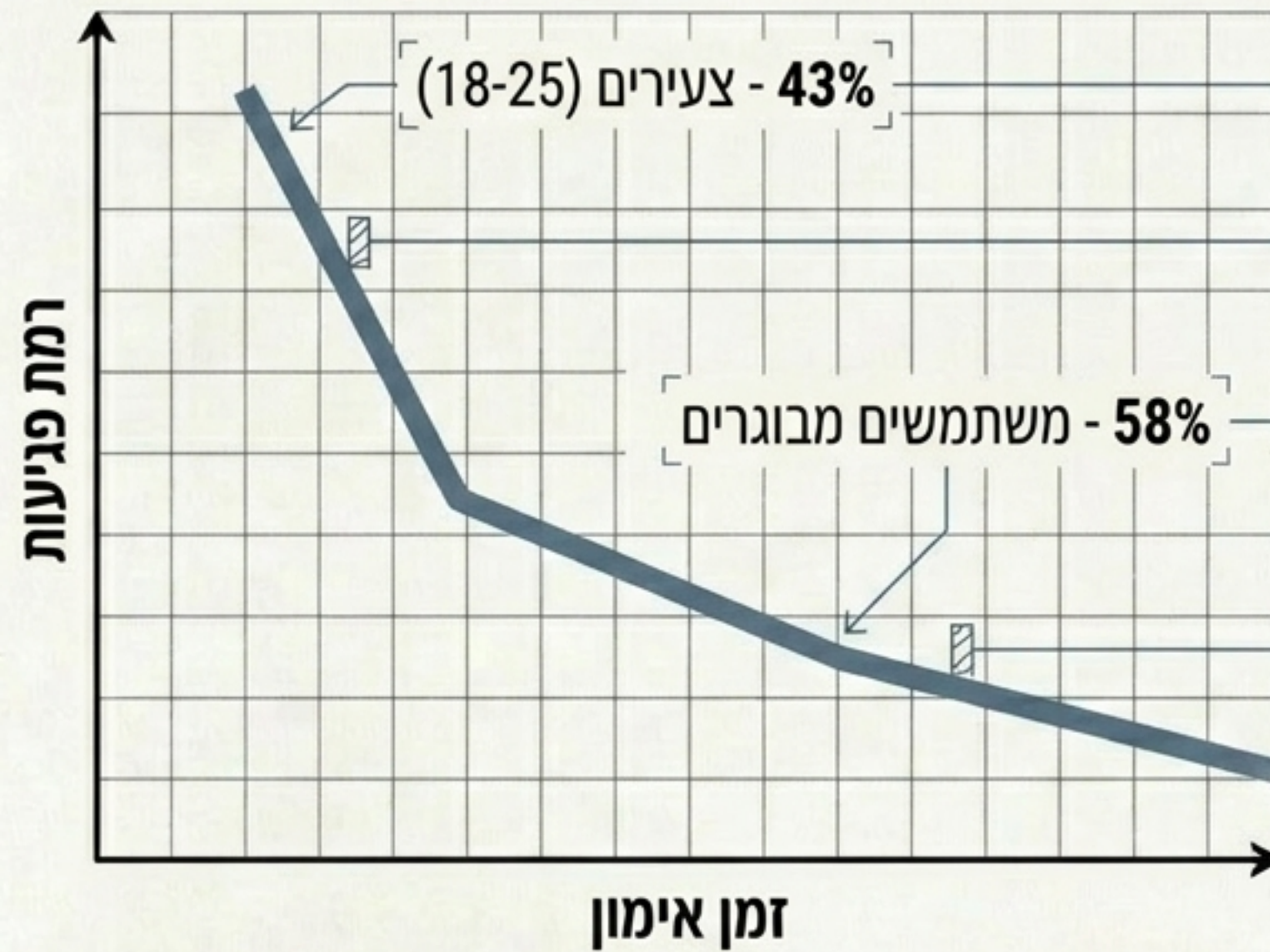
אימות בסיסי (SMS 2FA)

דורש גורם נוסף, אך פגיע לחלוטין בפני
התקפות אדם-באמצע (MitM), החלפת
SIM ופישיוג בזמן אמת.

סיסמאות בלבד

קלות לניחוש, חשופות
לדליפות נתונים ולהנדסה
חברתית בסיסית.

המגן - חלק ג': החומה האנושית



המציאות הסטטיסטית:

מחקרים מראים שיעורי הקלקה גבוהים בקרב כלל קבוצות הגיל **ללא** אימון.

קמפיינים מדומים (Simulated Phishing):

הדרך היעילה ביותר לכיול מחדש של מודעות אודעות ארגונית.

מיומנויות הליבה:

זיהוי חוסר התאמה בין כתובות לטקסט, סירוב לבקשות מידע חריגות, ועמידות בפני דחיפות.

מול התקפה מושלמת הנדסית, הספקנות האנושית היא המגן האחרון.

כללי ברזל להישרדות דיגיטלית

1



סמכו, אך אמתו מחוץ לערוץ (Out-of-Band)

קיבלתם דרישה דחופה מגורם רשמי? אל תשתמשו בקישור בהודעה. בהודעה. היכנסו באופן עצמאי לאתר או התקשרו למספר המוכר.

2

היזהרו מדחיפות מזויפת

מניפולציה של זמן היא הנשק העיקרי של התוקף. פנייה שמחייבת פעולה מיידית עקב סכנה סכנה לחשבון היא לרוב הונאה.

3

עברו לאימות מבוסס מבוסס חומרה

נטשו את מנגנוני ה-SMS ודחפו לאימוץ מפתחות אבטחה פיזיים (WebAuthn / FIDO), החסינים בפני מתקפות חטיפת עוגיות ו-MitM.

